CYBER
SECURITY

API Security Risk Analysis Report

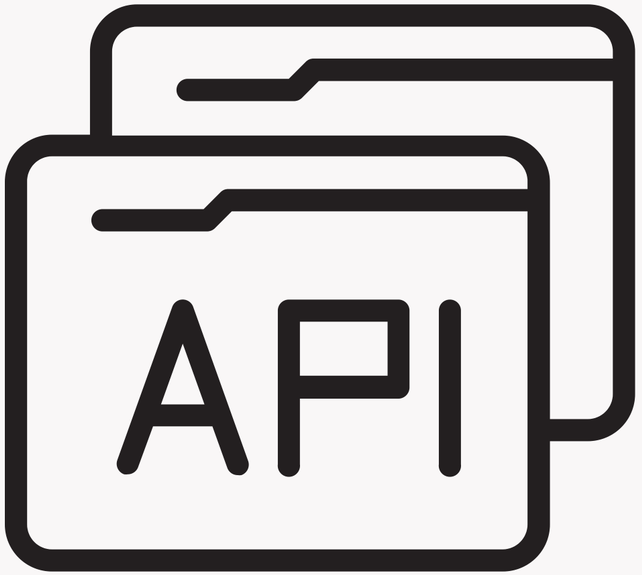
Internship : Cyber Security Internship
Organization : Future Interns

Prepared By :
Aishwarya Shankar
aishwaryashankar007@gmail.com

Introduction

APIs (Application Programming Interfaces) are widely used in modern applications such as mobile apps, SaaS platforms, and web services. However, insecure APIs can expose sensitive data and lead to serious security risks.

This report presents a security analysis of a public test API to identify potential vulnerabilities and provide remediation recommendations.



API Selected

API Name : JSONPlaceholder (Test API)

Base URL : https://jsonplaceholder.typicode.com

jsonplaceholder.typicode.com/users

All Bookmarl

Pretty print


```
[
  {
    "id": 1,
    "name": "Leanne Graham",
    "username": "Bret",
    "email": "Sincere@april.biz",
    "address": {
      "street": "Kulas Light",
      "suite": "Apt. 556",
      "city": "Gwenborough",
      "zipcode": "92998-3874",
      "geo": {
        "lat": "-37.3159",
        "lng": "81.1496"
      }
    },
    "phone": "1-770-736-8031 x56442",
    "website": "hildegard.org",
    "company": {
      "name": "Romaguera-Crona",
      "catchPhrase": "Multi-layered client-server neural-net",
      "bs": "harness real-time e-markets"
    }
  },
  {
    "id": 2,
    "name": "Ervin Howell",
    "username": "Antonette",
    "email": "Shanna@melissa.tv",
    "address": {
      "street": "Victor Plains",
      "suite": "Suite 879",
      "city": "Wisokyburgh",
      "zipcode": "90566-7771",
      "geo": {
        "lat": "-43.9509",
        "lng": "-34.4618"
      }
    },
    "phone": "010-692-6593 x09125",
    "website": "anastasia.net",
    "company": {
      "name": "Deckow-Crist",
      "catchPhrase": "Proactive didactic contingency",
      "bs": "synergize scalable supply-chains"
    }
  },
  {
    "id": 3,
    "name": "Clementine Bauch",
    "username": "Samantha",
```


Endpoints Tested :

- /users
- /users/1

Tools Used

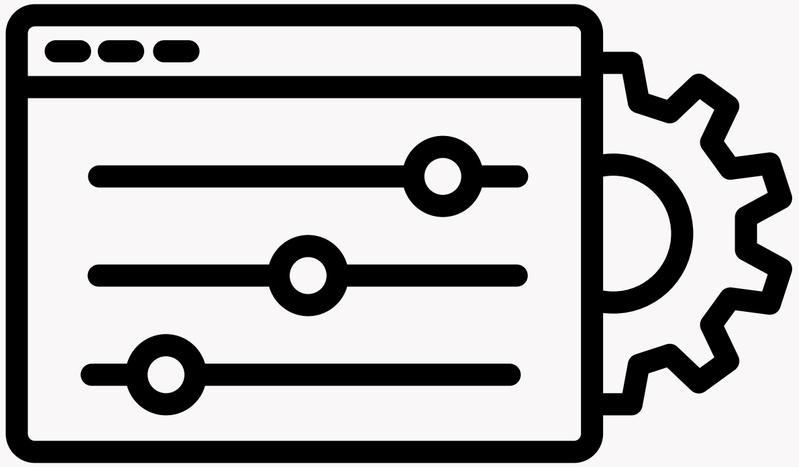
- Browser (for direct API access)
- Browser DevTools (Network & Headers analysis)
- Postman (API testing & response inspection)
- Canva(Report making)

Canva

Methodology

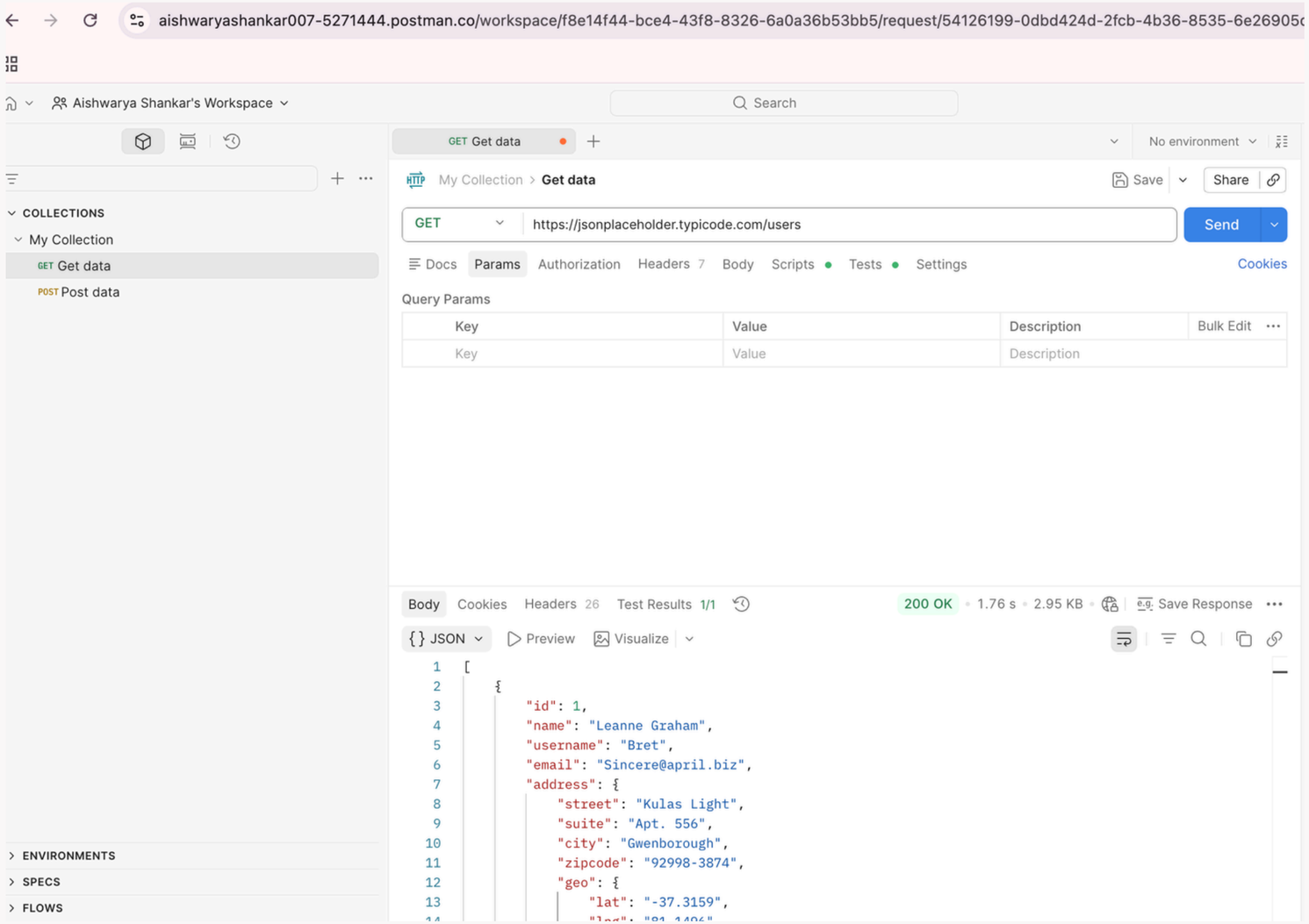
The following approach was used :

1. Accessed API endpoints via browser.
2. Inspected requests using DevTools.
3. Tested endpoints using Postman.
4. Analyzed headers and responses.
5. dentified security risks.
6. Classified severity.
7. Suggested remediation steps.



Testing & Observations

Endpoint : /users. The /users endpoint was tested using both a web browser and Postman.



Observations :

- The API returned a list of multiple users.
- The response included the following data :
- Name
- Email
- Address
- Phone number
- Company details

No authentication or API key was required to access this endpoint.

Endpoint : /users/1. The /users/1 endpoint was used to retrieve information about a single user.

jsonplaceholder.typicode.com/users/1

Pretty print

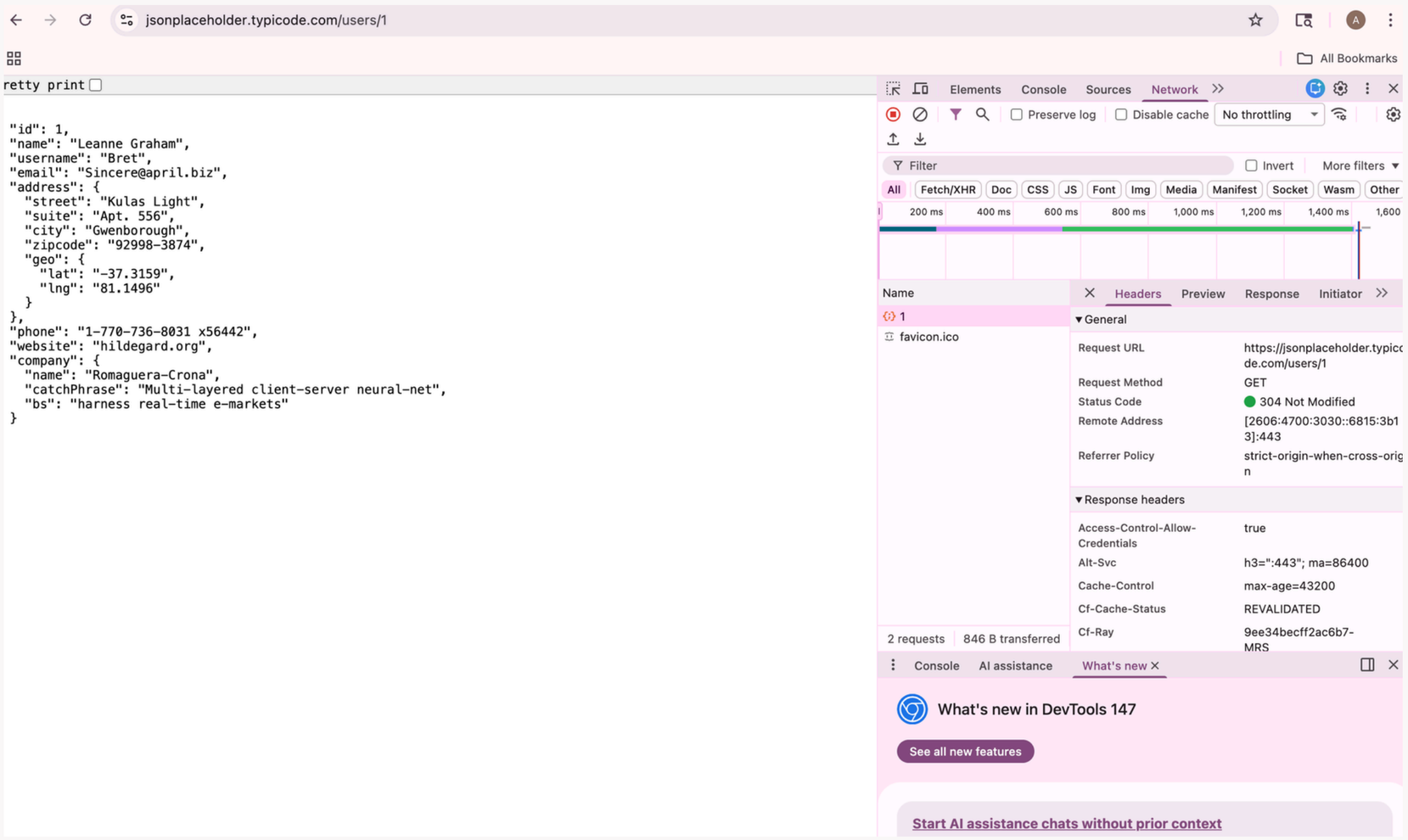

```
{
  "id": 1,
  "name": "Leanne Graham",
  "username": "Bret",
  "email": "Sincere@april.biz",
  "address": {
    "street": "Kulas Light",
    "suite": "Apt. 556",
    "city": "Gwenborough",
    "zipcode": "92998-3874",
    "geo": {
      "lat": "-37.3159",
      "lng": "81.1496"
    }
  },
  "phone": "1-770-736-8031 x56442",
  "website": "hildegard.org",
  "company": {
    "name": "Romaguera-Crona",
    "catchPhrase": "Multi-layered client-server neural-net",
    "bs": "harness real-time e-markets"
  }
}
```


Observations :

1. The API returned detailed data for one user.
2. Sensitive information such as email and address was visible .
3. The endpoint was publicly accessible without authentication.

Header Analysis (DevTools)

The request and response headers were analyzed using browser DevTools.



Observations :

1.Request method used : GET.

2 .No Authorization header present.

3.No API key or token required.

4.Response status code: 200 OK.

Security Risks Identified

1. **No Authentication :** API endpoints are accessible without login or authentication.
   Severity : High
   Impact : Unauthorized users can access sensitive data.

2. **No Authorization Control :** Users can access any user's data by modifying the endpoint (e.g., /users/1, /users/2).
   Severity : High
   Impact : Leads to unauthorized access to other users' information.

3. **Excessive Data Exposure :** API returns complete user details including personal information.
   Severity : Medium
   Impact : Increases risk of privacy breaches and misuse of data.

4. **Missing Rate Limiting :** No restriction on the number of API requests.
   Severity : Medium
   Impact : API can be abused or overloaded by attackers.

5. **Lack of Input Validation :** No visible validation mechanisms in tested endpoints.
   Severity : Low
   Impact : May allow unexpected or malicious input in real-world scenarios.

Recommendations

1. Implement authentication mechanisms (API keys, tokens).
2. Apply proper authorization and access control.
3. Limit data exposure to only necessary fields.
4. Implement rate limiting to prevent abuse.
5. Add input validation and sanitization.
6. Use secure API design practices.

Conclusion

The analysis identified several common API security risks such as lack of authentication, improper access control, and excessive data exposure. While the tested API is intended for learning purposes, these issues highlight real-world vulnerabilities that can lead to serious security breaches.

Organizations must implement strong security measures to protect APIs and ensure safe data handling.

Thank You